การตอบคอมเมนต์อาจารย์ที่ปรึกษา

Hybrid IDS สำหรับ Campus SOC — สรุปสิ่งที่แก้ไข วิธีแก้ และผลที่วัดได้
ฉบับวันที่ 1 พฤศจิกายน 2569

> **คอมเมนต์ที่ 1 (อาจารย์)**
>
> “ไม่สามารถรวม unsupervised และ supervised dataset ได้ ดังนั้นไปพิจารณา dataset ที่นำมาใช้ และวิธีการวัดประสิทธิภาพใหม่ค่ะ”

> **คอมเมนต์ที่ 2 (อาจารย์)**
>
> “ทำไมเลือกใช้ ML สามตัวนี้ เพราะมันมีหลายโมเดลมาก”

สรุปสั้นที่สุด

คอมเมนต์ที่ 1 ถูกต้อง และกลไกที่อาจารย์ชี้มีอยู่จริง ไม่ได้แก้ด้วยการอธิบายว่าของเดิมพอใช้ได้ แต่แก้ที่ชั้นข้อมูล — **เลิกการ join สองชุดข้อมูลทิ้งทั้งหมด** ให้ทั้งสามโมเดลอ่านไฟล์เดียวกัน ชุด feature เดียวกัน และ split เดียวกัน

การแก้นี้ทำให้เกิดผลที่**ไม่ได้คาดไว้และเปลี่ยนสถาปัตยกรรมหลัก**: เมื่อวัดใหม่อย่างยุติธรรม กฎรวมผลที่ใช้อยู่เดิมกลายเป็นแพ้ Random Forest ตัวเดียว จึงต้องเปลี่ยนกฎ — รายละเอียดอยู่ในหัวข้อ 2 และ 3

คอมเมนต์ที่ 2 ตอบด้วยการวัด ไม่ใช่การอ้างอิง เพิ่ม XGBoost เป็นคู่เทียบบนข้อมูลชุดเดียวกัน ผลคือ XGBoost ไม่ชนะ จึงมีหลักฐานว่าทำไมเลือก RF — แต่ XGBoost เร็วกว่า 6 เท่า ซึ่งต้องรายงานด้วย

1. คอมเมนต์ที 1 — ปัญหาจริงคืออะไร

ก่อนแก้ ระบบอ่านข้อมูลจาก **สองชุดที่ถูกสกัดแยกกัน** ด้วย CICFlowMeter จาก capture เดียวกัน:

- Random Forest (supervised) อ่านชุด **MachineLearningCSV** □ 80 features
- Isolation Forest + Autoencoder (unsupervised) อ่านชุด **GeneratedLabelledFlows** □ 92 features (มี behavioral features ที่ต้องใช้ IP/Timestamp)

สองชุดนี้ไม่มีคีย์เชื่อมกัน ต้องใช้ **row-hash join** ซึ่งจับคู่แถว BENIGN ได้เพียง **76.4%** ผลคือ ensemble ประเมินได้แค่ **80.36%** ของ test split แล้วนำไปเทียบกับ RF ที่เห็นข้อมูล 100%

> **เหตุผลที่คอมเมนต์อาจารย์ถูก**
>
> การเทียบ ensemble (80.36% ของข้อมูล) กับ RF (100% ของข้อมูล) ไม่ใช่การเทียบที่ยุติธรรมตั้งแต่ต้น และ 405,142 แถวที่ใช้ประเมินเป็น artifact ของการ join ไฟล์ ไม่ใช่สิ่งที่ระบบจริงจะเห็น

2. วิธีแก้ — เลิก join ไม่ใช่เถียงว่า join ดีพอ

ไฟล์ **cicids2017_behavioral_labeled.parquet** (2,520,961 แถว)
มีทุกคอลัมน์ที่ทั้งสามโมเดลต้องใช้อยู่แล้ว จึง **split 60/20/20 ตรงจากไฟล์นี้**
(**src/features/build_unified_population.py**)

	ก่อนแก้	หลังแก้
จำนวนชุดข้อมูล	2 ชุด สกัดแยกกัน	1 ชุด
การ join	row-hash join จำเป็น	ไม่มีการ join เลย
Coverage ของ test split	**80.36%**	**100.00%**
Feature set	**RF 80 / IF+AE 92 (คนละชุด)**	**94 ทุกโมเดล (ชุดเดียวกัน)**
Train / Val / Test	ไม่ตรงกันระหว่างโมเดล	1,780,362 / 504,192 / 504,193

หมายเหตุ: คอลัมน์ระบุตัวตน 5 ตัว (Flow ID, Source IP, Destination IP, Timestamp, day_group) ถูกตัดออกจาก input ของโมเดล — โดยเฉพาะ Source IP ถ้าปล่อยไว้โมเดลจะจำได้ว่า host ไหนโจมตีใน capture นี ซึ่งเป็น data leakage ที่ปลอมตัวมาเป็น feature

ข้อจำกัดที่การแก้นี้ไม่ได้ปลดล็อก: CIC-UNSW-NB15 ไม่มีคอลัมน์ Source IP / Timestamp จึงคำนวณ behavioral features 12 ตัวให้มันไม่ได้ ดังนั้น IF และ AE ยังเข้าร่วมการทดสอบข้าม dataset (M1c) ไม่ได้ — ดูหัวข้อ 6

3. ผลที่ไม่ได้คาดไว้ — กฎรวมผลต้องเปลี่ยน

เมื่อวัดใหม่บนข้อมูลชุดเดียวกันด้วย nested LOAO (เลือก threshold จาก 9 หมวดที่เหลือ แล้วไปใช้กับหมวดที่กันไว้) **กฎเดิมที่ใช้อยู่แพ้ Random Forest ตัวเดียว**

กฎรวมผล (candidate)	F1 (zero-day)	Recall	FPR
confidence_weighted □ ใช้จริงตอนนี้	**0.9782**	**0.9635**	**0.0007**
OR: RF หรือ AE (2 thresholds)	0.9745	0.9608	0.0011
RF ตัวเดียว	0.9737	0.9593	0.0011
OR: max(RF, AE) □ กฎเดิม	0.9724	0.9559	0.0010
AND: RF และ AE	0.9504	0.9062	0.0001
AE ตัวเดียว	0.8736	0.8176	0.0055
IF ตัวเดียว	0.4371	0.4502	0.0619

หาสาเหตุด้วย ablation ไม่ใช่เดา

เดิม กฎ OR ชนะ RF ตัวเดียวถึง 9.3pp — แต่ตอนนั้น RF ถูกจำกัดให้ใช้แค่ 80 features ไม่มี behavioral features เลย จึงทดสอบโดย**ตัดเฉพาะ 12 behavioral columns ออก** แล้วรัน LOAO ชุดเดิมซ้ำ (**rf_behavioral_ablation_loao.py**)

RF ตัวเดียว ในแต่ละเงื่อนไข	F1 (zero-day)	Recall
unified, 94 features (มี behavioral)	0.9737	0.9593
unified, 82 features (ตัด behavioral ออก)	0.8312	0.7942
population เก่าที่ join, 80 features	0.8327	0.7705

> **ข้อสรุปของ ablation**
>
> ตัด behavioral columns ออกแล้ว RF **ตกกลับไปทับ population เก่าแทบสนิท** (0.8312 เทียบ 0.8327) แปลว่า margin 9.3pp ของกฎ OR เดิม **มาจากการที่ RF ถูกมัดมือไว้** ไม่ใช่จากตัวกฎ — การเทียบเดิมไม่เป็นธรรมกับ RF มาตลอด

นอกจากนี้ยัง**ขัดกับข้อสรุปเดิมที่บันทึกไว้**ว่า behavioral features ไม่ช่วย RF เพราะเป็นข้อจำกัดของ supervised generalization ไม่ใช่เรื่องการแทน feature — ข้อสรุปนั้นมาจากการให้เหตุผลตามหลักการ **ไม่เคยวัด** เพราะ RF ไม่เคยได้รับ 12 คอลัมน์นั้นเลย

แต่ผลไม่สม่ำเสมอทุกหมวด: ที่ argmax behavioral columns ทำให้ RF แย่ลงบน DoS Slowhttptest (0.055 เมื่อมี เทียบ 0.275 เมื่อไม่มี) และ DoS slowloris (0.224 เทียบ 0.455) จึงต้องรายงานต่อหมวด ไม่ใช่สรุปรวมว่า “ช่วย”

กฎที่ใช้จริงตอนนี้

> **confidence_weighted — RF นำ มี unsupervised รองรับ**

> `rf_confidence = |P(attack) − 0.5| × 2`
> ถ้า `rf_confidence ≥ 0.95` □ ใช้คะแนนของ RF
> ถ้าไม่ถึง □ ใช้ `(if_norm + ae_norm) / 2`
> แจ้งเตือนเมื่อคะแนนรวม > 0.03

ห้าสามโมเดลมีส่วนร่วมจริง ซึ่งทำให้กรอบ “three-model ensemble” ยังใช้ได้ แต่ Isolation Forest ตัดสินเฉพาะแถวที RF ไม่มั่นใจ เพราะ FPR ของมันอยู่ที 0.09–0.15 สูงกว่า RF ประมาณพันเท่า ใช้เป็นตัวจุดชนวนอิสระไม่ได้

เหตุผลที่เคยปัดกฎนี้ตกไปใช้ไม่ได้แล้ว: ตอนนั้น tuner เลือก confidence_threshold = 1.00 ใน 9/10 fold ซึ่งเท่ากับปิดการทำงานของตัวเอง รอบนี้เลือก 0.95 ใน 9/10 fold แปลว่าทางรองรับทำงานจริง — ตรวจข้อนี้ก่อนตัดสินใจรับกฎ ไม่ใช่สมมติ

4. คอมเมนต์ที 2 — ทำไมเลือก ML สามตัวนี

คำตอบเดิมอ่อน เพราะ**ไม่เคยวัดคู่เทียบเลย** การเลือก Random Forest อาศัยความนิยม ไม่ใช่หลักฐาน จึงเพิม XGBoost ซึงเป็นคู่แข่งทีชัดทีสุด วัดบน population / feature / split เดียวกันทุกอย่าง (**baseline_model_comparison.py**)

โมเดล	เวลาเทรน	Inference (504k แถว)	F1	AUC
Random Forest (sklearn, CPU)	**231.5 s**	**5.45 s**	**0.9997**	**1.0000**
XGBoost (GPU)	38.7 s	0.94 s	0.9907	0.9961

XGBoost ไม่ชนะด้านการตรวจจับ และ per-category recall แพ้ RF เกือบทุกหมวด (Bot 0.931 เทียบ 0.972 · PortScan 0.986 เทียบ 1.000 · SSH-Patator 0.983 เทียบ 1.000) เหตุผลทีเลือก RF จึงกลายเป็น “วัดแล้วดีกว่า” แทน “เป็นทีนิยม”

> **สิงทีต้องพูดคู่กันเสมอ ไม่ใช่โชว์แค่คอลัมน์ F1**
>
> XGBoost **เทรนเร็วกว่า 6 เท่า และ inference เร็วกว่า 5.8 เท่า** ถ้าเกณฑ์คือ latency ในระบบจริง XGBoost ชนะชัดเจน ที RF ช้าเพราะ scikit-learn **ไม่มี GPU backend เลย** เป็นข้อจำกัดของไลบรารี ไม่ใช่การตังค่าทีไม่ดี

และสิงทีการวัดนี**ตอบได้จริงมีเพียงข้อเดียว**: ไม่มีทางเลือกทียังไม่ได้ทดสอบทีดีกว่าอย่างชัดเจน **ไม่ได้แปลว่า RF ดีทีสุด** — เพราะ in-dataset บน CICIDS-2017 อิมตัวแล้ว ต่างกันระดับพันส่วนของ F1 ไม่พิสูจน์อะไร ตัวทีแยกโมเดลออกจริงคือ zero-day LOAO

ไม่เพิม One-Class SVM โดยเจตนา: ฝัง unsupervised มีคำตอบอยู่แล้ว เพราะ IF และ AE มี per-category recall correlation 0.925–0.977 (ซ้ำซ้อนกันสูง) และ LOAO ablation ก็ตัด IF ออกจากการตัดสินใจหลักไปแล้ว

5. วิธีวัดประสิทธิภาพใหม่ — 4-way ablation บน test split เดียวกัน

คอมเมนต์อาจารย์สั่งให้พิจารณา "วิธีการวัดประสิทธิภาพใหม่" ด้วย จึงพบและแก้**ข้อผิดพลาดในตารางหลัก**: rule-based SIEM baseline ยังอ่าน population เก่า ขณะที ensemble ย้ายไป unified แล้ว ตัวเลขสองตัวที่เอามาเทียบกัน**มาจาก test set คนละชุด**

Arm ของ ablation	Precision	Recall	F1	FPR
Rule-based SIEM	0.8297	0.8980	0.8625	0.0375
Hybrid (confidence_weighted)	0.9952	0.9981	0.9966	0.00098
RF ตัวเดียว	0.9995	0.9995	0.9995	0.00009

ทุกตัวเลขวัดบน test split เดียวกัน n = 504,193 แถว

ค่ารวมของ SIEM หลอกตา ต้องรายงานต่อหมวด

F1 0.8625 มาจาก DDoS 0.988 · DoS Hulk 0.983 · PortScan 0.933 เป็นหลัก ขณะที **8 จาก 14 หมวดได้ 0.000 เป๊ะ** (Bot, FTP-/SSH-Patator, Web Attack ทั้งสามแบบ, Heartbleed, Infiltration) และอีกสองหมวดเกือบศูนย์ (DoS slowloris 0.006 · DoS Slowhttptest 0.007)

- rule R1 (port scan) ยิงโดนแถว attack **ศูนย์แถว** แต่สร้าง false positive 4,240 ครั้ง — recall ของ PortScan มาจาก rule R3 (volume) ไม่ใช่ R1
- rule R2 (brute force) target recall 0.000 แต่ไปจับ DoS Hulk และ DDoS แทน
- rule R5 (beaconing) ไม่ยิงอะไรเลย

จุดที hybrid แพ้ และต้องเขียนในเล่ม

> **ต้องรายงานสองทาง ไม่ใช่ทางเดียว**
>
> **zero-day LOAO:** hybrid 0.9782 ชนะ RF ตัวเดียว 0.9737 (+0.45pp) ที FPR ดีกว่า (0.0007 เทียบ 0.0011)
> **in-dataset:** hybrid 0.9966 **แพ้** RF ตัวเดียว 0.9995 และ FPR แย่กว่า 10 เท่า (0.00098 เทียบ 0.00009)
>
> ข้อสรุปที่ตรงไปตรงมาคือ hybrid แลก precision ใน dataset กับความสามารถ generalize ไปหา zero-day และบน dataset นี้ส่วนต่างแคบพอที่ผู้อ่านจะเลือก RF ตัวเดียวอย่างมีเหตุผลได้

6. M1c — ทดสอบข้าม dataset แล้วพังทั้งสองทาง

วัดด้วย **eval_cross_dataset.py** รายงาน **สามแถวต่อทิศ ไม่ใช่สองแถว** เพราะคะแนนข้าม dataset เดียวๆ แยกไม่ออกว่า “generalize ไม่ได้” หรือ “ชุด feature ร่วมอ่อนกว่า”

ทิศ	โมเดล	วัดบน	F1	AUC	FPR
CICIDS□UNSW	full 80f	CICIDS test	0.9958	0.9998	0.0009
CICIDS□UNSW	shared 76f	CICIDS test	0.9958	0.9999	0.0011
CICIDS□UNSW	shared 76f	UNSW test	0.0006	0.3220	0.0000
UNSW□CICIDS	full 76f	UNSW test	0.9551	0.9933	0.0274
UNSW□CICIDS	shared 76f	UNSW test	0.9551	0.9933	0.0274
UNSW□CICIDS	shared 76f	CICIDS test	0.1139	0.5034	0.2103

การพังเป็น generalization ทั้งหมด ไม่ใช่ผลจากการตัด feature — ตัดลงเหลือ shared set เสีย F1 เพียง −0.0001 ทิศหนึ่ง และ 0.0000 อีกทิศ ถ้าไม่มีแถวกลางนี้จะเถียงไม่ได้เลย

- **CICIDS□UNSW: AUC 0.3220 ต่ำกว่า 0.5** คือ**การจัดอันดับกลับทิศ** — โมเดลให้คะแนนแถว attack ว่า benign มากกว่าแถว benign จริงอย่างเป็นระบบ รุนแรงกว่าแค่ generalize ไม่ได้ (precision 1.0000 ในแถวนั้น**ห้ามนำไปอ้าง** มันเป็น artifact ของการยิงแทบไม่เคยยิง)
- **UNSW□CICIDS: AUC 0.5034** คือสุ่ม พร้อม FPR 0.2103 ยิงโดน benign หนึ่งในห้า

> **สิ่งที่ M1c สร้างให้วิทยานิพนธ์**
>
> ขอบเขตของข้อกล่าวอ้างแบบ dataset เดียว — นี่เป็นหลักฐานที่แข็งที่สุดที่มีว่า in-dataset F1 ~0.9996 **ไม่ใช่** ข้อกล่าวอ้างเรื่องการใช้งานบน traffic ใหม่ ผลพังข้าม dataset เป็นสิ่งที่ต้องรายงานตรงๆ ไม่ใช่การทดลองที่ล้มเหลว

ข้อจำกัด: วัดได้เฉพาะ Random Forest เพราะ behavioral features 12 ตัวต้องใช้ Source IP / Timestamp ซึ่ง CIC-UNSW-NB15 ไม่มี — ผลนี้ไม่บอกอะไรเกี่ยวกับ generalizability ของ cascade ที่ใช้จริง และต้องไม่รายงานเป็นผลของ ensemble

7. ส่วนทีวัดเพิมครบในรอบนี

MTTD (M1b) — ตัวเลขหลักใช้ไม่ได้ และบอกไว้ตรงๆ

ค่า MTTD ต่อ campaign ออกมา **0.0000 วินาที** ซึง**ไม่ใช่ผลทีดี แต่เป็นตัวเลขทีไม่มีความหมาย** — flow แรกของทัง 228 campaign ถูกตรวจจับได้ทุกอัน เพราะ flow แรกมี behavioral vector เป็นศูนย์ทัง 12 คอลัมน์ (ถูกต้องทางกายภาพ: source IP ยังไม่มี activity ใน window) และกฎให้คะแนนเฉลีย 8.94 เทียบ threshold 0.03

ตัวที**อ้างได้** คือค่าทีตัด flow แรกของแต่ละ campaign ออก:

Attack class	campaigns	MTTD เฉลีย	median	max
port_scan	4	0.00 s	0.00 s	0.01 s
credential_stuffing	6	0.14 s	0.15 s	0.31 s
brute_force	10	0.98 s	0.53 s	2.63 s
c2_beacon	34	193.27 s	204.15 s	482.94 s
data_exfil	174	451.53 s	417.41 s	888.97 s

รูปร่างสมเหตุสมผล: burst จับได้ทันที low-and-slow ใช้ 3–7 นาที · ไม่มี campaign ไหนหลุด ·
แต่ห้ามอ่านอัตราการตรวจจับบน overlay นีเป็นหลักฐานความสามารถ เพราะ behavioral columns ของ overlay อ่อนกว่าข้อมูลจริงมาก (conn_count_1m สูงสุด 0.014 เทียบ 1.0 ในข้อมูลจริง)

SHAP — อธิบายได้ครังแรกเพราะการแก้ซันข้อมูล

SHAP attribute **เฉพาะ branch ทีตัดสินแถวนันจริง** โดยแถวที fallback ตัดสินจะ attribute ฟังก์ชันผสม `(if_norm + ae_norm)/2` ตรงๆ ซึง**ทำได้เพราะทังสามโมเดล ใช้ feature space เดียวกันแล้ว** — ใต้ดีไซน์เดิมทีแยกสองชุด การเฉลียคะแนนข้าม space ทีเข้ากันไม่ได้ไม่มีความหมายในการ attribute

- Faithfulness (|base + □shap − คะแนนจริง|): RF **1.96e-10** · fallback **4.66e-09**
- Latency: RF 0.258 s/alert · fallback 0.184 s — ใช้ได้ต่อ alert ไม่เหมาะกับการ score จำนวนมาก
- **ยืนยัน ablation โดยอิสระ:** feature อันดับต้นของ RF กลายเป็น behavioral columns (uniq_dport_count_5m 0.0517 · uniq_dport_count_3m 0.0417) โดย Destination Port ลงไปอันดับ 3

Branch mix — เหตุผลที cascade มีคุณค่าซึงตาราง LOAO มองไม่เห็น

> **ผลทีน่าเก็บไว้**
>
> ใน dataset ปกติ RF ตัดสิน **99.785%** ของแถว fallback เพียง 0.215% — แต่บน synthetic overlay ซึงเป็น input นอก distribution **RF งดออกเสียงทุกแถว และ fallback ตัดสิน 100% ของ alert**
> นีคือทางรองรับทำงานตามทีมันมีอยู่เพือสิงนี และเป็นข้อโต้แย้งให้ cascade เหนือ RF ตัวเดียว

8. ข้อจำกัดที่ต้องเขียนในเล่ม

รายการนี้บันทึกไว้ใน **models/fusion_config.json** ไม่ใช่เขียนขึ้นใหม่ตอนทำรายงาน

ข้อจำกัด	ตัวเลข / สภาพจริง
hybrid แพ้ RF ตัวเดียวใน dataset	F1 0.9966 เทียบ 0.9995 · FPR แย่กว่า 10 เท่า — เลือก hybrid เพราะชนะ zero-day
Bot ตรวจไม่ได้เลย	nested recall 0.000 · ทุกสมาชิกเกือบศูนย์ ไม่มีกฎรวมใดกู้คืนได้
ตัด IF ออกจากการตัดสินมีต้นทุนจริง	IF เป็นตัวที่ดีที่สุดบน DoS Slowhttptest (0.839 เทียบ AE 0.241, RF 0.055) แต่ FPR 0.09–0.15
สองหมวดไม่มี redundancy	FTP-Patator และ Web Attack - Brute Force ขึ้นกับ RF ตัวเดียว · PortScan ขึ้นกับ AE ตัวเดียว
in-dataset metric อิมตัว	RF val F1 0.9997 — แยกโมเดลไม่ออก ต้องใช้ zero-day LOAO เท่านั้น
M1c วัดได้แค่ RF	behavioral features ต้องใช้ IP/Timestamp ซึ่ง CIC-UNSW-NB15 ไม่มี
MTTD ตัวเลขหลัก degenerate	ต้องอ้างค่าที่ตัด flow แรกออก และบอกเหตุผลที่ตัด
LLM layer ยังไม่ผ่านการตรวจคุณภาพ	ยืนยันผลผลิตบน alert จริงไม่เกิน 2 เคส
PA-5220 log จริงไม่มีและไม่ใช้	อยู่นอกขอบเขตถาวร (ตัดสินใจ 25 ต.ค. 2569) — CICIDS-2017 เป็นชุดเทรนชุดเดียว

9. สิ่งที่ยังไม่ได้ทำ

- A/B analyst triage-time study (≥15 analysts × 20 alerts/group, blinded) — ยังไม่ได้เก็บข้อมูล
- LINE / Gmail ส่งจริง — ยังเป็น dry-run (sandbox ไม่มี outbound internet · Gmail OAuth2 เว้นว่างไว้)
- Kafka broker จริงและ OpenCTI จริงกับ enrich.py — ผ่าน 27 tests บน stub แต่ยังไม่เคยต่อของจริง
- ตรวจคุณภาพผลผลิต LLM บน alert จำนวนมากพอ

ไฟล์อ้างอิงทั้งหมดอยู่ใน E:/thesis/reports/ — unified_val_metrics.csv · fusion_layer_loao_unified_or_comparison.csv · rf_behavioral_ablation_loao_report.txt · baseline_model_comparison.csv · siem_baseline_report.txt · cross_dataset_m1c_metrics.csv · mttd_metrics_excluding_first_flow.csv · shap_explainability_report.txt